

LETRA DE TAREA 1 — Opcion : Gestor de Contraseñas con Control Centralizado

Curso: Seguridad de la Información

Módulo: Práctica integradora — Blue Team / Red Team

Equipos: 2 (Blue Team y Red Team)

Modalidad: Open source obligatorio

Versión: 1.0

Fecha: [DD/MM/AAAA]

0. Resumen de la tarea

Desarrollar un **gestor de contraseñas de uso local** (offline-capable) con un **control centralizado** en la organización. El control centralizado recibe notificaciones de auditoría (por correo) ante cualquier alta, modificación o borrado de contraseñas y ante **cambios de la contraseña maestra**. La solución debe:

- Funcionar **sin conexión** para el usuario final (los secretos se gestionan de forma local).
- Adoptar principios **Zero Trust** y buenas prácticas criptográficas.
- Integrar **SIEM/HIDS + dashboard** de alertas, incidentes y funcionamiento.
- Requiere instalar (libre elección del equipo, todas open source): **servidor de correo** (notificaciones), **Security Onion** (opcional para SIEM), **Wazo** (opcional para comunicaciones/alerta), además del propio gestor.
- Permitir en su UI local **definir por sistema**: el tipo de contraseña a generar, la **expresión regular** aplicable, historial, vencimiento, notas, categorías, importación/exportación (segura).
- Soporte de autenticación con **TOTP, WebAuthn/U2F, Windows Hello**, con elección de algoritmo de hash (Argon2id/bcrypt) en el control centralizado.

La tarea se desarrolla en **dos partes**:

1. **Parte 1 (Blue Team):** diseñar, implementar y documentar la solución completa.
2. **Parte 2 (Red Team):** el equipo Red Team recibe la solución terminada y debe **atacarla** y emitir un informe técnico.

0.1 Perfil MCU 5.0 objetivo: **AVANZADO**

El perfil de cumplimiento del **Marco de Ciberseguridad 5.0 (AGESIC)** exigido para las tres tareas es el **perfil comunitario AVANZADO** (el más exigente de los tres: Básico, Estándar, Avanzado). Esto significa que:

- Los controles a justificar son los del perfil **Avanzado** (no solo el mínimo).
- Se deben completar y entregar los **Excel** de apoyo del MCU 5.0 desde la carpeta `plantilla/mcu5/excel/`:
 - 01-controles-mcu5-perfil-avanzado.xlsx — registro de controles por función con **evidencia** y **cómo se demuestra**.
 - 02-registro-activos-mcu5.xlsx — inventario de activos (ID-01).
 - 03-matriz-raci-mcu5.xlsx — matriz de responsabilidades por proceso.
 - 04-bitacora-planilla.xlsx — bitácora de trabajo (ver sección de bitácora).
- Para cada control se debe indicar **si aplica (Sí/No/N.A.)**, y para los **N.A.** dejar la **justificación** escrita. Un control que no aplica debe justificarse y aceptarse; no se elimina silenciosamente.

0.2 Modelo de arquitectura obligatorio

La arquitectura debe presentarse con las plantillas de `plantilla/`:

- `plantilla-arquitectura-4más1.md` (vistas 4+1: lógica, procesos, desarrollo, física + escenarios), y
- `plantilla-arquitectura-C4.md` (contexto, contenedores, componentes, código).

Ambas deben entregarse antes de la demo funcional en la auditoría.

0.3 Calendario del curso (obligatorio)

Hito	Fecha	Evento
Pre-entrega Blue Team	miércoles 7 de octubre de 2026	Entrega congelada + arranque de auditoría
Entrega / Defensa Blue Team	miércoles 14 de octubre de 2026	Auditoría formal por función
Pre-entrega Red Team	miércoles 28 de octubre de 2026	Informe Red Team preliminar
Entrega final Red Team	lunes 9 de noviembre de 2026	Informe Red Team final + presentación

1. Marco teórico

1.1 Gestión de contraseñas y secretos

Uno de los medios de acceso más explotados es el **robo/reutilización de contraseñas**. Un gestor de contraseñas local concentra el riesgo en una sola pieza bien protegida (la **bóveda cifrada por la contraseña maestra**). Principios:

- **Derivación de clave (KDF) robusta:** Argon2id / bcrypt / scrypt con salt único (no cifrar directamente con la contraseña).
- **Cifrado fuerte de la bóveda:** AES-256-GCM/XChaCha20-Poly1305; autenticación AEAD para detección de manipulación.
- **Secretos nunca en texto plano ni en logs;** el control central solo recibe **eventos de auditoría** (metadatos), no los secretos.
- **No confiar en el servidor:** el servidor central no puede descifrar las bóvedas (Zero Knowledge).

1.2 Zero Trust (NIST SP 800-207)

- Toda solicitud se considera hostil hasta verificarse.
- Acceso mínimo privilegio, sesiones cortas, MFA.
- El control central solo ve una *superficie controlada* (eventos), no el contenido.

1.3 Arquitectura de auditoría

- El gestor **emite eventos firmados** (JSON Web Token / HMAC) hacia el control central.
- El control central registra en SIEM, notifica por correo y alimenta un dashboard.
- **Cambio de contraseña maestra** = evento crítico → notificación inmediata + revalidación.

1.4 Marcos normativos aplicables (Uruguay)

- **MCU 5.0 (AGESIC):** funciones **Proteger** (PR), **Detectar** (DE), **Responder** (RS).
- **BCU — GSI:** 2FA obligatorio para operaciones de alto valor; monitoreo de cambios en datos sensibles; logs y retención; notificación de incidentes relevantes.
- **URCDP — Ley 18.331:** protección de datos personales.
- **ISO/IEC 27001:2022:** A.5.15-A.5.19 (accesos), A.8.1 (criptografía), A.8.15/16 (logs), A.5.24 (incidentes).
- **COBIT 2019:** APO13, DSS05, DSS02.

1.5 Referencias técnicas

Tema	Referencia
Derivación de claves	OWASP Password Storage Cheat Sheet (Argon2id)

Tema	Referencia
TOTP	RFC 6238
WebAuthn / U2F	FIDO2 WebAuthn Level 1/2
Cifrado AEAD	AES-256-GCM, XChaCha20-Poly1305
Zero Trust	NIST SP 800-207
SIEM/HIDS	Wazuh; Security Onion (Suricata + Zeek + Elastic)
Color/gestión memnónica	XKCD 936 (passphrases)

2. Glosario (específico de la tarea)

Término	Definición
Bóveda	Almacén cifrado donde se guardan las credenciales del usuario.
Contraseña maestra	Clave que, mediante KDF, protege la bóveda local.
Control central	Servidor de la organización que recibe eventos de auditoría y notifica.
Evento de auditoría	Registro firmado de una operación (alta/modificación/borrado/cambio de maestra).
Zero-knowledge	Propiedad por la cual el servidor nunca conoce secretos, solo eventos.
TOTP	Contraseña de un solo uso basada en tiempo (RFC 6238).
FIDO2/WebAuthn	Autenticación sin contraseña con llaves de seguridad.
Argon2id	KDF moderna (memoria-T).
SIEM	Plataforma que correlaciona y almacena eventos de seguridad.
HIDS	Detección de intrusos a nivel de host (integridad, log).
Security Onion	Distribución open source de NIDS/SIEM.
Wazo	PBX/comunicaciones open source (canal de aviso telefónico).
Regex	Expresión regular para validar/generar contraseñas por sistema.

3. Requerimientos funcionales (RF)

ID	Requerimiento
RF-01	Almacenamiento local de bóvedas cifradas con KDF (Argon2id/bcrypt) y cifrado AEAD.
RF-02	Crear, abrir, cerrar bóveda con contraseña maestra + MFA opcional local.
RF-03	Alta, consulta, modificación y borrado de credenciales por sistema/recurso.
RF-04	Definir por sistema : plantilla de contraseña (longitud, caracteres), expresión regular requerida, historial de N contraseñas, días de validez, categorías y notas.
RF-05	Generador de contraseñas con opción de passphrase (XKCD) y modo “cumplir regex”.
RF-06	Modo offline : operación completa sin conexión a la organización.
RF-07	Notificaciones por correo (servidor de mail propio) ante: alta, modificación, borrado y cambio de la contraseña maestra .
RF-08	Envío de eventos de auditoría firmados (HMAC/JWS) al control central.
RF-09	Dashboard del control central: alertas, incidentes, estado de agentes, volumen de eventos, KPIs.
RF-10	Integración SIEM (Wazuh/Security Onion) con reglas de detección (brute-force de maestra, borrado masivo, cambio de maestra).
RF-11	Gestión de usuarios del control central con roles; MFA (TOTP/WebAuthn/Windows Hello) configurable; elección de algoritmo de hash.
RF-12	Importación/exportación de bóveda en formato cifrado (con contraseña de

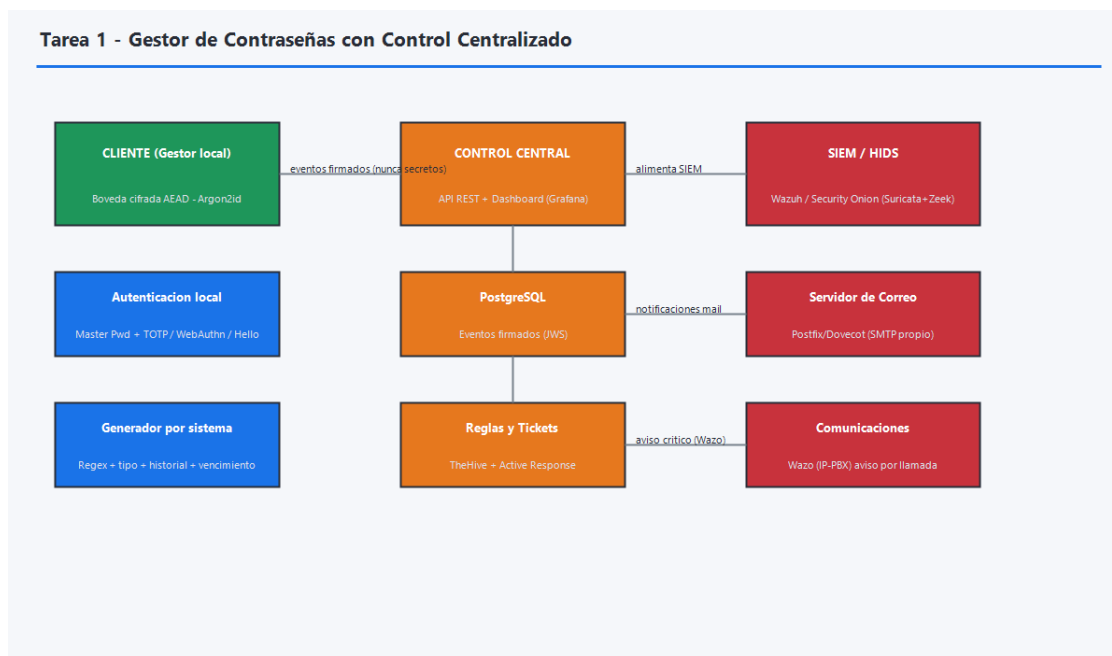
ID	Requerimiento
	transporte).
RF-13	Registro de incidentes a partir de alertas y su estado (abierto/en análisis/resuelto).
RF-14	Panel de “funcionamiento”: agentes activos, última sincronización, estado del servidor de mail.
RF-15	Buscador y filtros (por categoría, sistema, vencimiento, favoritos).
RF-16	Protección de la bóveda contra fuerza bruta: delay adaptativo / hash memory-hard.
RF-17	Aviso de vencimiento de contraseñas (local y por evento al control central).

4. Requerimientos no funcionales (RNF)

ID	Requerimiento
RNF-01	Cero dependencia de red para el uso cotidiano del gestor (offline).
RNF-02	Rendimiento: apertura de bóveda < 2 s; UI fluida en recursos modestos (4 GB RAM).
RNF-03	Disponibilidad del control central 99% en horario laboral; recuperable en < 4 h (RTO).
RNF-04	Usabilidad: completar operativa básica sin instrucciones; mensajes claros.
RNF-05	Escalabilidad: soportar 100 usuarios con 5000 credenciales; 10 agentes por control central.
RNF-06	Seguridad: contraseñas nunca en logs/BD central; cifrado en tránsito (TLS 1.2+); JWS firmado.
RNF-07	Auditabilidad: todos los eventos retenidos $\geq$ 90 días; traza completa.
RNF-08	Portabilidad: gestor en Windows/Linux; o web local desplegable en contenedor.
RNF-09	Todo open source y sin licencias comerciales.

ID	Requerimiento
RNF-10	Mantenibilidad: documentación de despliegue, config y rollback.
RNF-11	Cumplimiento: evidencia trazable para MCU 5.0, BCU, ISO 27001 y Ley 18.331.

5. Arquitectura sugerida



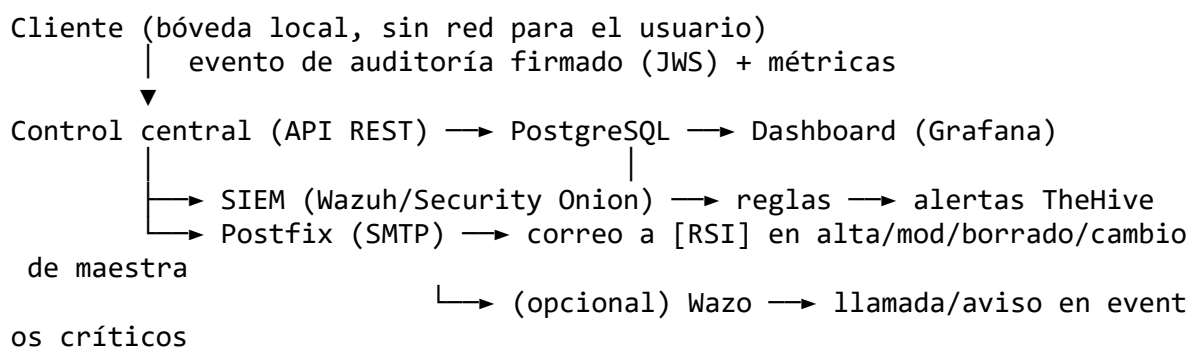
Arquitectura Tarea 1

Obligatorio: documentar la arquitectura con las plantillas **4+1** (plantilla/plantilla-arquitectura-4más1.md) y/o **C4** (plantilla/plantilla-arquitectura-C4.md). En el diagrama se muestran las vistas lógica/procesos/física, y la demo funcional siempre arranca con el diagrama de arquitectura.

Capa/Componente	Tecnologías open source sugeridas	Rol
Cliente (gestor)	KeePassXC o app propia; Bitwarden-Vaultwarden (self-hosted) o versión propia web	Bóveda local offline
Autenticación	WebAuthn/TOTP + Argon2id/bcrypt (Elección propia)	MFA
Control central	Contenedor Docker + Gitea/Forgejo (código);	Recepción de eventos, dashboard

Capa/Componente	Tecnologías open source sugeridas	Rol
	PostgreSQL o SQLite	
Notificación	Postfix/Dovecot (SMTP propio) o Mailu	Envío de correos
SIEM	Wazuh (agentes en clientes + servidor) o Security Onion (Suricata+Zeek+Elastic)	Detección y correlación
SOAR/Alertas	TheHive (gestión de casos) + Alertmanager/Grafana o Wazuh Active Response	Respuesta y paneles
Comunicaciones (opcional)	Wazo (IP-PBX) para aviso telefónico de alertas críticas	Verificación humana
Dashboard	Grafana + Wazuh / ELK (Kibana)	Alertas/incidentes/funcionamiento

Flujo de datos



El gestor **nunca envía secretos**; solo eventos firmados. Las bóvedas permanecen cifradas en el cliente.

6. Parte 1 — Blue Team

6.1 Objetivo

Implementar la solución completa, operativa en el laboratorio del curso (VMs dentro del sandbox del curso), con documentación de seguridad completa.

6.2 Entregables del Blue Team

#	Entregable	Plantilla/documento	Fase
---	------------	---------------------	------

#	Entregable	Plantilla/documento	Fase
1	Arquitectura y diagrama	docs/00-arquitectura.md	Diseño
2	Política de seguridad	01-politica-seguridad	Inicio
3	Inventario y clasificación de activos	02-registro-activos	Diseño
4	Análisis de riesgos	03-analisis-riesgos	Diseño
5	Gestión de accesos (TOTP/WebAuthn/Hello/Argon2)	09-gestion-accesos	Implementación
6	Monitoreo, logs y SIEM (reglas)	07-monitoreo-logs	Implementación
7	Gestión de vulnerabilidades	10-gestion-vulnerabilidades	Pre-entrega
8	Plan de continuidad (copias de las bóvedas exportadas)	06-plan-continuidad	Implementación
9	Registro de incidentes simulado	04-gestion-incidentes	Validación
10	SoA y brecha MCU 5.0	11-soa-plan-tratamiento	Cierre
11	Notificación de pruebas BCU/URCDP	12-notificacion-incidentes	Cierre
12	Repositorio GIT (código) con tag de entrega	—	Entrega
13	Evidencias del funcionamiento (capturas, video ≤ 5 min)	docs/evidencias/	Entrega
14	Informe Blue Team con KPIs	docs/28-informe-blue-team.md	Entrega

6.4 KPIs requeridos

- Tiempo de detección de un ataque simulado (MTTD).
- Tiempo de respuesta a incidente (MTTR).
- Cobertura de eventos notificados (100% de alta/mod/borrado/cambio de maestra).
- Tasa de falsos positivos del SIEM.
- Uptime del control central durante la validación.

6.5 Bitácora de trabajo (obligatoria)

Cada equipo debe llevar una **bitácora diaria** del trabajo. Se documenta en:

- Plantilla: `plantilla/isaca/99-bitacora-trabajo.md` (+ Excel `plantilla/mcu5/excel/04-bitacora-planilla.xlsx`).
- Reglas: registro **diario** (no la noche anterior a la entrega); cada miembro firma sus entradas; **no se omiten fallos** (un error registrado y corregido suma en la auditoría); hora UTC; referenciar evidencia real en `docs/evidencias/`.
- La bitácora del Blue Team cubre diseño, implementación, pruebas y ajustes; la del Red Team cubre cada intento de ataque.
- En la auditoría, cada control se valida contra las entradas de bitácora correspondientes.

6.6 La auditoría (evaluación de la Parte 1)

La instancia de evaluación del Blue Team **no es una simple demo: es una auditoría de seguridad formal**. El equipo se presenta como si rindiera una **auditoría de certificación**, y la cátedra (auditores) recorre las **funciones del MCU 5.0: Gobernar, Identificar, Proteger, Detectar, Responder, Recuperar**.

Proceso de la auditoría (orden obligatorio de presentación):

Paso	Qué se presenta	Tiempo sugerido
1	Demo funcional del sistema arrancando + diagrama de arquitectura (4+1 y C4), mostrando el sistema funcionando en vivo	10 min
2	Recorrido por Gobernar (política, RACI, roles)	5 min
3	Recorrido por Identificar (activos, riesgos, vulnerabilidades)	10 min

Paso	Qué se presenta	Tiempo sugerido
4	Recorrido por Proteger (accesos, cifrado, backups)	10 min
5	Recorrido por Detectar (SIEM/logs/reglas/alertas)	10 min
6	Recorrido por Responder (incidentes, SOAR, notificaciones)	10 min
7	Recorrido por Recuperar (BCP, restauración)	5 min
8	Cierre: riesgos residuales + SoA + preguntas	10 min

Cómo se evalúa cada función / control:

- Para **cada control** del Excel 01-controles-mcu5-perfil-avanzado el equipo debe tener:
 - **Evidencia** concreta (archivo, captura, log, registro) en docs/evidencias/.
 - **Cómo se demuestra**: el paso en vivo o la prueba documentada que viabiliza el control.
 - **Aplicabilidad**: marcar Sí/No/N.A. con **justificación** para todo lo que no aplique.
- El auditor (docente) **puede pedir la demostración en vivo** de cualquier control del Excel. Si el control está declarado pero no se puede demostrar, se considera **hallazgo de auditoría**.
- La defensa concluye con la **SoA** y el reporte de **nivel de madurez** por función.

7. Parte 2 — Red Team

7.1 Reglas de compromiso

- **Alcance autorizado**: solo el entorno del laboratorio del curso.
- **No**: exfiltración real, DoS destructivo no pactado, ataques fuera de las VMs docentes.
- **Ventana activa**: del **28 de octubre al 9 de noviembre de 2026** (pre-entrega 28/10; entrega final 09/11).
- El Red Team **no** modifica la entrega; documenta hallazgos.
- El Red Team mantiene **bitácora diaria de ataques** (04-bitacora-planilla.xlsx).

- **Pre-entrega (28/10):** informe preliminar con al menos el 70% de los hallazgos detectados y su repro.
- **Entrega final (09/11):** informe completo según plantilla/informe-red-team.md + presentación ejecutiva.

7.2 Objetivos del Red Team (listar todos los que apliquen)

ID	Objetivo
RT-01	Obtener acceso a una bóveda (crackear derivación/tamaño de clave, fuerza bruta de maestra).
RT-02	Interceptar/alterar eventos de auditoría (forjar JWS/HMAC) y comprobar si el control central lo detecta.
RT-03	Comprometer el control central (IDOR, XSS, inyección SQL) y obtener datos de auditoría o elevar privilegio.
RT-04	Suplantar el servidor de correo (relay abierto, SPF/DKIM inexistente) y falsificar notificaciones.
RT-05	Realizar un ataque de man-in-the-middle si el TLS no es correcto o se aceptan certificados autofirmados.
RT-06	Saltarse el MFA (TOTP phishing, enroll de token ajeno).
RT-07	Envenenar el dashboard (XSS almacenado en campos de eventos).
RT-08	Evadir la detección del SIEM (activar/borrar las reglas, exfiltración silenciosa).
RT-09	Abusar de la importación/exportación para forzar una colisión o degradar el cifrado.
RT-10	Exfiltrar secretos mediante errores de la aplicación (logs de depuración, stack traces).
RT-11	Realizar OSINT del repositorio (secretos commiteados, Dockerfiles vulnerables).
RT-12	Ataque de denegación de servicio puntual al control central (acreditado pero acotado).

7.3 Herramientas permitidas al Red Team (open source)

Burp Suite Community, OWASP ZAP, nmap, sqlmap, John the Ripper, hashcat, Hydra, ffuf, nuclei, enum4linux, BloodHound, impacket, Metasploit (autorizado en sandbox), curl/jq, Goo .NET / etc.

7.4 Entregables del Red Team

#	Entregable	Contenido mínimo
1	Informe de evaluación (según plantilla/informe-red- team.md)	Metodología, alcance, reglas de compromiso
2	Inventario de hallazgos	Severidad (CVSS), evidencia (capture), repro (pasos)
3	Mapeo MITRE ATT&CK	Tácticas/técnicas usadas
4	Registro de incidentes (plantilla)	Cada hallazgo como INC- ####
5	Conclusión y RPO/RTO verificado	Backups/restauración probados
6	Presentación ejecutiva (10 min)	Resumen a la clase
7	Bitácora Red Team	04-bitacora- planilla.xlsx completa día a día

7.5 Presentación del Red Team (entrega final 09/11)

Qué se espera que presenten (en este orden):

Paso	Contenido
1	Resumen ejecutivo (número de hallazgos por severidad, postura global)
2	Demo/evidencia de los 3 hallazgos más críticos (repro en vivo o video)
3	Evaluación de la eficacia de los controles del Blue Team frente a cada función MCU
4	Respuesta del Blue Team a cada hallazgo (respuesta inmediata, siguiente iteración de la defensa)
5	Entrega del informe final (plantilla informe-red-team.md) y de la bitácora

Formato del informe: usar sí o sí la plantilla `plantilla/informe-red-team.md`, convertida a DOCX, completa.

7.5 Criterios de evaluación del Red Team

- Cantidad y severidad de hallazgos válidos (sin falsos positivos no justificados).
- Evidencia reproducible y técnica.
- Calidad del informe (estructura ISACA).
- Cumplimiento de reglas de compromiso y ética.

8. Matriz de documentación (qué plantilla, cuándo, con qué)

8.1 Fase 1 — Blue Team (semana del 14/09 al 07/10/2026)

Plantilla	Cuándo llenarla	Con qué evidencia	Para qué requisito
01-politica-seguridad	1ª semana (borrador) — 30/09 (final)	Diseño, RF	MCU 5.0 GV; BCU req. 1; ISO A.5.1
02-registro-activos	1ª semana y actualizaciones	Diagrama, docker ps, IPs, versiones	MCU 5.0 ID; ISO A.5.9
03-analisis-riesgos	18/09 (v1) y 06/10 (v2)	Escaneos, diseño	MCU 5.0 ID; BCU req. 3
09-gestion-accesos	23-30/09	Capturas de enroll TOTP/WebAuthn/Hello, config hash	BCU 2FA; ISO A.5.15-19
07-monitoreo-logs	28/09-01/10	Reglas SIEM, alertas, retención	MCU 5.0 DE; ISO A.8.15/16
10-gestion-vulnerabilidades	01-05/10	Escaneos OpenVAS/nuclei/AST	ISO A.8.8
06-plan-continuidad	28/09-01/10	Copias exportadas + prueba de restauración	BCU backups; ISO A.5.29
04-gestion-incidentes	02-05/10	Incidentes simulados	MCU 5.0 RS; ISO A.5.24
11-soa-plan-tratamiento	05-07/10	SoA ISO completa + brecha MCU (perfil Avanzado)	ISO 27001; BCU
12-notificacion-incidentes	05-07/10	Borrador de notificación (simulado)	Ley 18.331; BCU

Plantilla	Cuándo llenarla	Con qué evidencia	Para qué requisito
GLOSARIO	14/09-07/10	Complementar con términos propios	—
Excel 01- controles-mcu5- perfil-avanzado	Semanal (cada avance)	Evidencias de cada control + cómo se demuestra	MCU 5.0 perfil Avanzado (obligatorio)
Excel 02- registro- activos-mcu5	1ª semana y actualizaciones	Activos reales del despliegue	MCU 5.0 ID-01
Excel 03-matriz- raci-mcu5	23/09	Procesos con responsables	MCU 5.0 GV
Excel 04- bitacora- planilla	Diario	Entradas firmadas	Todos
Arquitectura 4+1	18/09	Diagrama completo (4 vistas + escenarios)	Identificar / Presentación
Arquitectura C4	18/09	Contexto/Contenedores/Componentes/Código	Identificar / Presentación

8.2 Entrega a Red Team

Cómo: git tag v1.0 en el repositorio + árbol de docs/ congelado + video demo (máximo 5 min). **Cuándo:** **Miércoles 07/10/2026 (pre-entrega)**; sirve de base a la auditoría del 14/10. **Con qué:** hash (SHA-256) del tag para garantizar integridad; el Red Team verificará que no se modificó durante la evaluación.

8.3 Fase 2 — Red Team (28/10 al 09/11/2026)

Plantilla	Cuándo llenarla	Con qué evidencia
04-gestion-incidentes (reutilizada)	Cada hallazgo = nuevo incidente	Capturas, repro
10-gestion-vulnerabilidades (reutilizada)	Vulnerabilidades explotables confirmadas	Escaneos, explotación
03-analisis-riesgos (reutilizada)	Riesgos residuales validados	Resultado de la intrusión
informe-red-team	Pre-entrega 28/10 (70%) y final 09/11	Documento completo según plantilla
99-bitacora-trabajo / Excel bitácora	Diario	Ataques, repro, resultado

8.4 Cierre (ambos equipos, 09/11/2026)

- **Foro de lecciones aprendidas** donde Blue Team responde a cada hallazgo (mitigado/no mitiga/plan).
- Actualizar docs/ con las correcciones realizadas post-evaluación.
- Cargar evidencia en la plataforma del curso.

9. Criterios globales de evaluación

Criterio	Peso	Detalle
Cumplimiento de RF	25%	Todos los RF implementados y demostrables
Calidad de la documentación (plantillas + Excel MCU)	20%	Completas, con evidencia y mapeo normativo correcto
Auditoría (por función MCU, con evidencia y demo en vivo)	25%	Desempeño en la defensa del 14/10
Desempeño Red Team	20%	Hallazgos válidos y bien documentados
Presentación y trabajo en equipo (incl. bitácora)	10%	Video + reportes + foro

Requisito de aprobación: la **auditoría** de las funciones **Proteger** y **Detectar** debe demostrarse en vivo; si el auditor encuentra que un control declarado no es demostrable, se descuenta del puntaje de auditoría.

10. Anexos

- Anexo A — Requisitos técnicos del entorno de laboratorio (VMs por equipo).
- Anexo B — Conjunto mínimo de datos de prueba a cargar (20+ sistemas con credenciales).
- Anexo C — Plantilla de reglas de compromiso firmadas por ambos equipos.
- Anexo D — Plantillas de arquitectura 4+1 y C4 (plantilla/).
- Anexo E — Excel de controles/activos/RACI/bitácora (plantilla/mcu5/excel/).
- Anexo F — Plantilla de informe Red Team (plantilla/informe-red-team.md).